

KALINGA INSTITUTE OF INDUSTRIAL TECHNOLOGY

Deemed to be University, Bhubaneswar - 751024, Odisha

MID SEMESTER EXAMINATION — SOLUTIONS & MARKING SCHEME

Subject: Cybersecurity

Time: 1.5 Hours

Semester / Programme: 7th Semester

Full Marks: 20

Instructions: Answer Question No. 1 (Compulsory) and any THREE from Question No. 2 to 5. Figures in brackets indicate marks.

SECTION - A (Compulsory)

1(a) Why is the classic model for network security essential before designing a secure system? [1]

Solution & Key Concept:

- Identify the fundamental components of information transfer: sender, receiver, and trusted/untrusted channel.
- Establish the security requirements (Confidentiality, Integrity, Availability) prior to mechanism selection.

Answer: It provides a foundational framework to identify vulnerabilities, select appropriate security transformations, and manage security-related secret information.

Marking Rubric: [1 Mark] for explaining the conceptual mapping of security goals to communication channels.

1(b) Differentiate briefly between Authentication Header (AH) and Encapsulating Security Payload (ESP) in IPsec. [1]

Solution & Key Concept:

- Compare AH and ESP protocols within the IPsec framework.
- Note the presence vs absence of encryption.

Answer: AH provides data integrity, origin authentication, and anti-replay protection, but *no* encryption. ESP provides all these *plus* confidentiality (encryption) of the payload.

Marking Rubric: [1 Mark] for correctly stating that ESP provides encryption while AH does not.

1(c) Why is DNS poisoning considered more damaging than ARP poisoning? [1]

Solution & Key Concept:

- Analyze the scope and persistence of both attacks.
- Compare local network bounds (ARP) with global/hierarchical scope (DNS).

Answer: ARP poisoning is typically restricted to a local area network (LAN) segment, whereas DNS poisoning affects global name resolution, potentially redirecting worldwide traffic to malicious servers.

Marking Rubric: [1 Mark] for highlighting the global/widespread impact versus local LAN restriction.

1(d) What is the primary function of a Demilitarized Zone (DMZ) in network architecture? [1]

Solution & Key Concept:

- Define the physical or logical placement of a DMZ between internal and external networks.
- State its purpose in exposing public-facing services safely.

Answer: A DMZ isolates public-facing services (like web and mail servers) from the internal corporate network, providing an extra layer of defense if public servers are compromised.

Marking Rubric: [1 Mark] for defining the isolation of public services from the internal network.

1(e) Distinguish between a corporate Policy and a Law in the context of Cyber Law and Ethics. [1]

Solution & Key Concept:

- Examine the source of authority and consequences for each.
- Contrast organizational enforcement with judicial enforcement.

Answer: A policy is an internal set of rules defined by an organization with administrative penalties for violation, whereas a law is enacted by a legislative governing body with statutory and criminal/civil penalties.

Marking Rubric: [1 Mark] for differentiating organizational rules/penalties from state/legislative laws.

SECTION - B (Answer any THREE)

Answer any THREE questions from Q.2 to Q.5. Each question carries 5 marks.

- Q.2.** (a) Explain the OSI/TCP-IP-based Model for Network Access Security. How does it handle unauthorized access threats at different layers? [3]

Solution for (a):

- Define the network access security model focusing on the gatekeeper function (e.g., passwords, access control lists).
- Explain how it counters unauthorized log-ins or hacking attempts.
- Discuss internal controls such as intrusion detection and firewalls protecting against masqueraders and bypassers.

Result / Conclusion: The model uses gatekeeper functions to authenticate users and internal controls to monitor and filter unauthorized traffic across network layers.

Marking Rubric: [1.5 Marks] for explaining the gatekeeper model, [1.5 Marks] for handling unauthorized access threats.

- (b) Discuss the implementation layers for security protocols within the TCP/IP protocol stack and analyze their security implications. [2]

Solution for (b):

- Identify key layers in TCP/IP where security can be implemented (Network layer like IPsec, Transport layer like TLS/SSL, Application layer like HTTPS/SSH).
- Analyze implications: Lower layer (Network) provides transparent security for all apps; upper layer provides fine-grained application-specific controls.

Result / Conclusion: Security can be implemented at Network (IPsec), Transport (TLS), or Application layers, each offering different trade-offs in transparency, overhead, and granularity.

Marking Rubric: [1 Mark] for identifying layers and protocols, [1 Mark] for analyzing architectural and security implications.

Q.3. (a) Explain the operational mechanics of Internet Key Exchange (IKE) in IPsec. Differentiate between its two phases. [3]

Solution for (a):

- Define IKE as the protocol used to set up a security association (SA) in the IPsec protocol suite.
- Describe Phase 1 (Main Mode / Aggressive Mode): Establishes a secure, authenticated communication channel (ISAKMP SA).
- Describe Phase 2 (Quick Mode): Uses the secure channel established in Phase 1 to negotiate IPsec SAs (AH/ESP) for actual data transfer.

Result / Conclusion: IKE automates key management and SA establishment in two distinct phases: Phase 1 builds a secure management channel, and Phase 2 negotiates data-transfer SAs.

Marking Rubric: [1 Mark] for general IKE overview, [1 Mark] for Phase 1 explanation, [1 Mark] for Phase 2 explanation.

(b) What is a Man-in-the-Middle (MitM) attack? Illustrate how a replay attack differs from a standard MitM eavesdropping scenario. [2]

Solution for (b):

- Define MitM: An attacker secretly relays and possibly alters the communication between two parties who believe they are directly communicating.
- Define Replay Attack: An attacker intercepts valid data transmission and maliciously or fraudulently repeats/delays it.
- Differentiate: MitM involves active real-time interception and potential modification; a replay attack retransmits previously captured legitimate packets without necessarily altering their content in real-time.

Result / Conclusion: MitM is active real-time manipulation of a session, whereas a replay attack involves recording valid data packets and re-sending them later.

Marking Rubric: [1 Mark] for MitM definition, [1 Mark] for differentiating replay attack mechanics.

Q.4. (a) Explain how ARP Poisoning works step-by-step. What countermeasures can be deployed to mitigate this vulnerability on a local network? [3]

Solution for (a):

- Explain the stateless nature of the Address Resolution Protocol (ARP).
- Describe how an attacker floods the target host/gateway with forged gratuitous ARP replies mapping their own MAC address to the victim's IP address.
- Detail countermeasures: Static ARP entries, Dynamic ARP Inspection (DAI) on switches, and encrypted communication protocols.

Result / Conclusion: ARP poisoning exploits stateless ARP tables by sending fake replies. Mitigation includes DAI, static ARP tables, and network monitoring.

Marking Rubric: [1.5 Marks] for step-by-step ARP poisoning mechanism, [1.5 Marks] for effective countermeasures (DAI, static tables).

(b) Compare Network Intrusion Detection Systems (NIDS) and Host-based Intrusion Prevention Systems (HIPS) in terms of placement and visibility. [2]

Solution for (b):

- Define NIDS placement (strategic points on the network, e.g., subnet routers) and visibility (monitors network traffic flows across multiple hosts).
- Define HIPS placement (installed on individual endpoints/servers) and visibility (monitors local OS activity, system calls, application logs, and local file modifications).

Result / Conclusion: NIDS monitors broad network traffic across segments, while HIPS protects specific host endpoints by analyzing internal OS and application-level behavior.

Marking Rubric: [1 Mark] for NIDS characteristics (placement & visibility), [1 Mark] for HIPS characteristics.

- Q.5. (a)** Classify the major types of Law relevant to cybersecurity and computer crimes. Provide a brief description of each. **[2.5]**

Solution for (a):

- Identify Criminal Law: Deals with conduct perceived as offensive to society as a whole, prosecuted by the state (penalties include fines and imprisonment).
- Identify Civil Law: Deals with disputes between individuals or organizations, seeking compensation or specific performance (tort law, contract disputes).
- Identify Administrative/Regulatory Law: Governs the regulations set by government agencies regarding data protection, privacy, and compliance.

Result / Conclusion: Major types include Criminal Law (state prosecution for societal offenses), Civil Law (private disputes and compensation), and Administrative Law (regulatory compliance).

Marking Rubric: [1 Mark] for Criminal law, [1 Mark] for Civil law, [0.5 Marks] for Administrative/Regulatory law.

- (b)** Discuss the scope and key protections offered by U.S. Copyright Law in the digital domain, particularly regarding software and digital media. **[2.5]**

Solution for (b):

- Define copyright scope: Protects original works of authorship fixed in any tangible medium of expression.
- Apply to digital domain: Covers source code, object code, databases, digital artwork, and multimedia.
- Discuss key rights: Exclusive rights to reproduce, distribute, perform, display, and create derivative works, alongside provisions like the DMCA (Digital Millennium Copyright Act) against anti-circumvention.

Result / Conclusion: U.S. Copyright Law protects original digital expressions, software code, and media, granting exclusive reproduction and distribution rights, reinforced by statutes like the DMCA.

Marking Rubric: [1.5 Marks] for scope and application to digital/software works, [1 Mark] for exclusive rights and DMCA anti-circumvention provisions.

--- END OF PAPER ---